

Cyberattacks

What is a cyberattack?

A cyberattack is an attempt by cybercriminals, hackers or other digital adversaries to access a computer network or system, usually for the purpose of altering, stealing, destroying or exposing information.

The primary objectives of a cyberattack can vary, including:

1. **Stealing Sensitive Information:** Accessing confidential data like personal information, financial data, intellectual property, or other important information.
2. **Disrupting Services:** Preventing legitimate users from accessing services, websites, or networks through attacks.
3. **Gaining Unauthorized Access:** Exploiting system vulnerabilities to gain unauthorized access to systems, allowing attackers to manipulate, steal, or destroy data.
4. **Extorting Money:** Demanding payment (ransom) to restore access to encrypted files or to stop further attacks.
5. **Sabotaging Infrastructure:** Attacking critical infrastructure such as power grids, healthcare systems, or transportation networks to cause widespread disruption.

Types of Cyberattacks

1. Malware
2. Denial-of-Service (DoS) Attacks
3. Phishing
4. Spoofing
5. Identity-Based Attacks
6. Code Injection Attacks
7. Supply Chain Attacks
8. Social Engineering Attacks
9. Insider Threats
10. DNS Tunneling
11. IoT-Based Attacks
12. AI-Powered Attacks

1. Malware

Malware — or malicious software — is any program or code that is created with the intent to do harm to a computer, network or server. Malware is the most common type of cyberattack, mostly because this term encompasses many subsets such as ransomware, trojans, spyware, viruses, worms, keyloggers, bots, and any other type that leverages software in a malicious way.

Type	Description
Ransomware	In a ransomware attack, an adversary encrypts a victim's data and offers to provide a decryption key in exchange for a payment. Ransomware attacks are usually launched through malicious links delivered via phishing emails, but unpatched vulnerabilities and policy misconfigurations are used as well.
Spyware	Spyware is a type of unwanted, malicious software that infects a computer or other device and collects information about a user's web activity without their knowledge or consent.
Adware	Adware is a type of spyware that watches a user's online activity in order to determine which ads to show them. While adware is not inherently malicious, it has an impact on the performance of a user's device and degrades the user experience.
Trojan	A trojan is malware that appears to be legitimate software disguised as native operating system programs or harmless files like free downloads. Trojans are installed through social engineering techniques such as phishing or bait websites.
Worms	A worm is a self-contained program that replicates itself and spreads its copies to other computers. A worm may infect its target through a software vulnerability or it may be delivered via phishing or smishing. Embedded worms can modify and delete files, inject more malicious software, or replicate in place until the targeted system runs out of resources.
Rootkits	Rootkit malware is a collection of software designed to give malicious actors control of a computer network or application. Once activated, the malicious program sets up a backdoor that may deliver additional malware. Rootkit

Type	Description
	take this a step further by infecting the master boot record (MBR) prior to the operating system booting up, making them harder to detect.
<u>Mobile Malware</u>	Mobile malware is any type of malware designed to target mobile devices. Mobile malware is delivered through malicious downloads, operating system vulnerabilities, phishing, smishing, and the use of unsecured WiFi.
<u>Scareware</u>	Scareware tricks users into believing their computer is infected with a virus. Typically, a user will see scareware as a pop-up warning them that their system is infected. This scare tactic aims to persuade people into installing fake antivirus software to remove the “virus.” Once this fake antivirus software is downloaded, then malware may infect your computer.
<u>Keylogger</u>	Keyloggers are tools that record what a person types on a device. While there are legitimate and legal uses for keyloggers, many uses are malicious. In a keylogger attack, the keylogger software records every keystroke on the victim’s device and sends it to the attacker.
<u>Botnet</u>	Botnet is a network of computers infected with malware that are controlled by a bot herder. The bot herder is the person who operates the botnet infrastructure and uses the compromised computers to launch attacks designed to crash a target’s network, inject malware, harvest credentials, or execute CPU-intensive tasks.
<u>Wiper Attack</u>	A wiper attack is designed to permanently delete or corrupt data on targeted systems. They are often observed in geopolitical conflicts and in a hacktivism context.

2. Denial-of-service (DoS) attacks

A Denial-of-service (DoS) attacks is a malicious, targeted attack that floods a network with false requests in order to disrupt business operations.

In a DoS attack, users are unable to perform routine and necessary tasks, such as accessing email, websites, online accounts or other resources that are operated by a compromised

computer or network. While most DoS attacks do not result in lost data and are typically resolved without paying a ransom, they cost the organization time, money and other resources in order to restore critical business operations.

The difference between DoS and **Distributed Denial-of-service (DoS)** attacks to do with the origin of the attack. DoS attacks originate from just one system while DDoS attacks are launched from multiple systems. DDoS attacks are faster and harder to block than DOS attacks because multiple systems must be identified and neutralized to halt the attack.

3. Phishing

Phishing is a type of cyberattack that uses email, SMS, phone, social media, and social engineering techniques to entice a victim to share sensitive information — such as passwords or account numbers — or to download a malicious file that will install viruses on their computer or phone.

Type	Description
<u>Spear Phishing</u>	Spear phishing refers to a specific type of targeted phishing attack. The attacker takes the time to research their intended targets and then write messages the target is likely to find personally relevant. These types of attacks are aptly called “spear” phishing because of the way the attacker hones in on one specific target. The message will seem legitimate, which is why it can be difficult to spot a spear-phishing attack
Whale phishing	A whale phishing is a type of social engineering attack specifically targeting senior executives (whales) of the company employees with the purpose of stealing money or proprietary information about the business of operations.
<u>Smishing</u>	Smishing is the act of sending fraudulent text messages designed to trick individuals into sharing sensitive data such as passwords, usernames and credit card numbers. A smishing attack may involve cybercriminals pretending to be your bank or a shipping service you use.
<u>Vishing</u>	Vishing is a voice based phishing attack. It makes the fraudulent use of phone calls and voice messages pretending to be from a reputable organization to convince individuals to reveal private information such as bank details and passwords.

4. Spoofing

Spoofing is a technique through which a cybercriminal disguises themselves as a known or trusted source. In so doing, the adversary is able to engage with the target and access their systems or devices with the ultimate goal of stealing information, extorting money or installing malware or other harmful software on the device.

Type	Description
Domain spoofing	Domain spoofing is a form of phishing where an attacker impersonates a known business or person with fake website or email domain to fool people into the trusting them. Typically, the domain appears to be legitimate at first glance, but a closer look will reveal subtle differences.
Email Spoofing	Email spoofing is a type of cyberattack that targets businesses by using emails with forged sender addresses. Because the recipient trusts the alleged sender, they are more likely to open the email and interact with its contents, such as a malicious link or attachment.
IP Spoofing	IP spoofing is a type of malicious attack where the threat actor hides the true source of IP packets to make it difficult to know where they came from

5. Identity-based attacks

Identity-based attacks are extremely hard to detect. When a valid user's credentials have been compromised and an adversary is masquerading as that user, it is often very difficult to differentiate between the user's typical behavior and that of the hacker using traditional security measures and tools.

Type	Description
<u>Kerberoasting</u>	Kerberoasting is a post-exploitation attack technique that attempts to crack the password of a service account within the Active Directory (AD) environment. In a Kerberoasting attack, an adversary masquerades as an account user with a service principal name (SPN) and requests a ticket, which contains an encrypted password.
<u>Man-in-the-Middle (MITM) Attack</u>	A man-in-the-middle attack is a type of cyberattack in which an attacker eavesdrops on a conversation between two targets with the goal of collecting personal data, passwords or banking details, and/or to convince the victim to take an action such as changing login credentials, completing a transaction or initiating a transfer of funds.
<u>Pass-the-Hash Attack</u>	Pass the hash (PtH) is a type of attack in which an adversary steals a “hashed” user credential and uses it to create a new user session on the same network. It does not require the attacker to know or crack the password to gain access to the system. Rather, it uses a stored version of the password to initiate a new session.
<u>Golden Ticket Attack</u>	In a golden ticket attack, adversaries attempt to gain unlimited access to an organization’s domain by accessing user data stored in Microsoft Active Directory. The attacker exploits vulnerabilities in the Kerberos identity authentication protocol, allowing them to bypass authentication methods.
<u>Silver Ticket Attack</u>	A silver ticket is a forged authentication ticket often created when an attacker steals an account password. A forged service ticket is encrypted and enables access to resources for the specific service targeted by the silver ticket attack.
<u>Credential Harvesting</u>	In credential harvesting, cybercriminals gather user credentials — such as user IDs, email addresses, passwords, and other login information — en masse to then access systems, gather sensitive data, or sell it in the dark web.
<u>Credential Stuffing</u>	Credential stuffing attacks work on the premise that people often use the same user ID and password across multiple accounts. Therefore, possessing the credentials for one account may be able to grant access to other, unrelated account.
<u>Password Spraying</u>	The basics of a password spraying attack involve a threat actor using a single common password against multiple accounts on the same application. This avoids the account lockouts that typically occur when an attacker uses a brute force attack on a single account by trying many passwords.
<u>Brute Force Attacks</u>	A brute force attack is uses a trial-and-error approach to systematically guess login info, credentials, and encryption keys. The attacker submits combinations of usernames and passwords until they finally guess correctly.

6. Code injection attacks

Code injection attacks consist of an attacker injecting malicious code into a vulnerable computer or network to change its course of action. There are multiple types of code injection attacks:

Type	Description
<u>SQL Injection</u>	A SQL Injection attack leverages system vulnerabilities to inject malicious SQL statements into a data-driven application, which then allows the hacker to extract information from a database. Hackers use SQL Injection techniques to alter, steal or erase application's database data.
<u>Cross-Site Scripting (XSS)</u>	Cross Site Scripting (XSS) is a code injection attack in which an adversary inserts malicious code within a legitimate website. The code then launches as an infected script in the user's web browser, enabling the attacker to steal sensitive information or impersonate the user. Web forums, message boards, blogs and other websites that allow users to post their own content are the most susceptible to XSS attacks.
<u>Malvertising</u>	Malvertising attacks leverage many other techniques, such as <u>SEO poisoning</u> , to carry out the attack. Typically, the attacker begins by breaching a third-party server, which allows the cybercriminal to inject malicious code within a display ad or some element thereof, such as banner ad copy, creative imagery or video content. Once clicked by a website visitor, the corrupted code within the ad will install malware or adware on the user's computer.
<u>Data Poisoning</u>	Data poisoning is a type of cyberattack in which an adversary intentionally compromises a training dataset used by an Artificial Intelligence or Machine Learning model to manipulate the operation of that model. When dataset is manipulated during the training phase, the adversary can introduce biases, intentionally create erroneous outputs, introduce vulnerabilities, or otherwise influence predictive capabilities of the model.

7. Supply chain attacks

A supply chain attack is a type of cyberattack that targets a trusted third-party vendor who offers services or software vital to the supply chain. **Software supply chain attacks** inject malicious code into an application in order to infect all users of an app, while **hardware supply chain attacks** compromise physical components for the same purpose. Software supply chains are particularly vulnerable because modern software is not written from scratch: rather, it involves many off-the-shelf components, such as third-party APIs, open source code and proprietary code from software vendors.

8. Social engineering attacks

Social engineering is a technique where attackers use psychological tactics to manipulate people into taking a desired action. Through the use of powerful motivators like love, money, fear, and status, attackers can gather sensitive information that they can later use to either extort the organization or leverage such information for a competitive advantage.

Examples of social engineering attacks include:

Type	Description
Pretexting	In pretexting, attackers get access to information, a system, or a user by posing a false scenario that gains the victim's trust. This includes posing as an investment banker, an HR employee, or even an IT specialist.
Business email compromise (BEC)	In a BEC attack, attackers assume the identity of a trusted user to trick employees or company customers into making payments or sharing data, among other things.
Disinformation campaign	Disinformation campaigns are deliberate efforts to spread false information, especially for political or war-related reasons. Adversaries leverage social media networks that reach vast audiences to amplify false narratives through the prolific use of bots and fake accounts, creating a false sense of consensus.
Quid Pro Quo	Using the quid pro quo technique, attackers target users with an offer to pay in exchange for a product or service.
Honeytrap	Honeytrap attacks target individuals looking for love or friendship on dating apps/websites. Attackers create fake profiles and leverage the relationship-built overtime to trick the victim into giving them money, information, or access to their network to install malware.
Tailgating/Piggybacking	Tailgating, also known as piggybacking, is a type of attack conducted in person by tagging along behind a company employee and asking them to hold the door open. Once the adversary is inside the facilities, they physically try to steal or destroy sensitive information.

9. Insider threats

IT teams that solely focus on finding adversaries external to the organization only see half the picture. [Insider threats](#) are internal actors such as current or former employees that pose danger to an organization because they have direct access to the company network, sensitive data, and IP as well as knowledge of business processes, company policies, or other information that would help carry out such an attack.

Internal actors that pose a threat to an organization tend to be malicious in nature. Some motivators include financial gain in exchange for selling confidential information on the dark web and/or emotional coercion such as the ones used

in [social engineering tactics](#). But some insider threats are not malicious in nature — instead, they are negligent. To combat this, organizations should implement a [comprehensive cybersecurity training program](#) that teaches stakeholders to be aware of any potential attacks, including those potentially performed by an insider.

10. DNS tunneling

DNS Tunneling is a type of cyberattack that leverages domain name system (DNS) queries and responses to bypass traditional security measures and transmit data and code within the network.

Once infected, the hacker can freely engage in [command-and-control activities](#). This tunnel gives the hacker a route to unleash malware and/or to extract data, IP or other sensitive information by encoding it bit by bit in a series of DNS responses.

DNS tunneling attacks have increased in recent years, in part because they are relatively simple to deploy. Tunneling toolkits and guides are even readily accessible online through mainstream sites like YouTube.

11. IoT-based attacks

An internet of things (IoT) attack is any cyberattack that targets an IoT device or network. Once compromised, the hacker can assume control of the device, steal data, or join a group of infected devices to create a botnet to launch DoS or DDoS attacks

Given that the number of connected devices is expected to grow rapidly, cybersecurity experts expect IoT infections to grow as well. Furthermore, the deployment of 5G networks, which will fuel the use of connected devices, may also lead to an uptick in attacks.

12. AI-powered attacks

As AI and ML technology improves, the number of use cases has also increased. Just as cybersecurity professionals leverage AI and ML to protect their online environments, attackers also leverage these tools to get access to a network or steal sensitive information.

Type	Description
Adversarial AI/ML	Adversarial artificial intelligence and machine learning seek to disrupt the operations of AI and ML systems by manipulating or misleading them. They can do this by introducing inaccuracies in training data.
Dark AI	Dark AI is specifically engineered to leverage the benefits of incorporating AI and ML technology to exploit vulnerabilities. Dark AI usually goes unnoticed until the damage is done.
Deepfake	Deepfakes are AI-generated forgeries that appear very real and have the potential to reshape public opinion, damage reputations, and even sway political landscapes. These can come in the form of fake images, videos, audio, or more.
AI-generated social engineering	Attackers create fake chatbots or virtual assistants capable of having human-like interactions and engaging in conversations with users to get them to provide sensitive information.